

**Федеральное государственное автономное образовательное учреждение высшего
образования**

**«НАЦИОНАЛЬНЫЙ ИССЛЕДОВАТЕЛЬСКИЙ УНИВЕРСИТЕТ
«ВЫСШАЯ ШКОЛА ЭКОНОМИКИ»**

Московский институт электроники и математики им. Тихонова
Департамент электронной инженерии

Практическая работа №4
по курсу «Разработка защищенных программных систем»

Выполнил:

Студент группы МИБИ251

Крохин Алексей Сергеевич

Москва, 2025

Контрольные вопросы.....	3
Диаграмма потоков данных.....	3
Основные угрозы.....	3
Расчет риска.....	6
Ранжирование угроз и меры митигации.....	7
Соответствие угроз БДУ ФСТЭК.....	8

Контрольные вопросы

Диаграмма потоков данных

Разработана диаграмма потоков данных с использованием утилиты OWASP Threat Dragon (Рисунок 1).

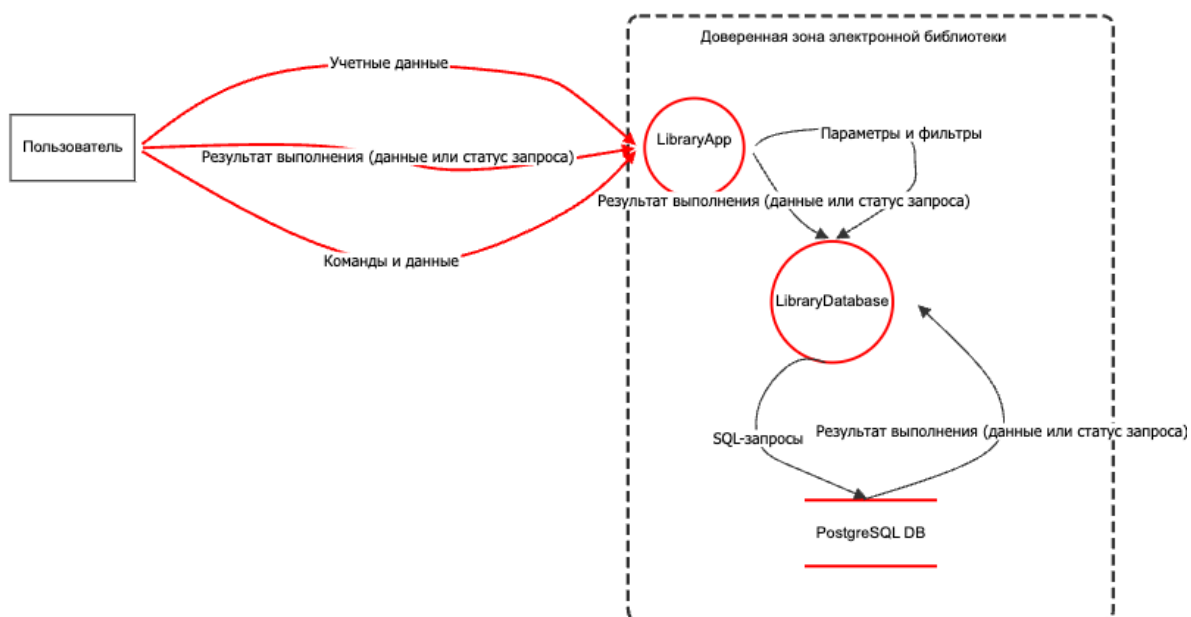


Рисунок 1 – Диаграмма потоков данных

Основные угрозы

Основные угрозы по методологии STRIDE приведены в Таблице 1.

Таблица 1 – Основные угрозы по STRIDE

ID	Компонент/Поток	Угроза STRIDE	Описание
T1	Поток: Учетные данные	Information Disclosure	Перехват учетных данных. Учетные данные (логин, пароль) могут быть перехвачены при передаче от Пользователя к приложению LibraryApp по незашифрованному или слабо защищенному каналу.
T2	Поток: Учетные данные	Tampering	Подмена данных пользователя. Злоумышленник может перенаправить соединение или подменить параметры подключения, заставив приложение подключиться к подконтрольной БД.
T3	Поток: Команды и данные	Information Disclosure	Перехват команд и данных. Конфиденциальные данные (имена книг, пользователей) и команды управления могут быть перехвачены при передаче.
T4	Поток: Команды и данные	Tampering	Подмена команд и данных. Злоумышленник может изменить передаваемые команды или данные (например, изменить сумму штрафа, подменить вставляемую в БД информацию).
T5	Поток: Результаты выполнения	Information Disclosure	Перехват данных из БД. Результаты запросов к базе данных (списки пользователей, книг) могут быть перехвачены.

T6	Процесс: LibraryApp	Spoofing	Подбор учетных данных. Кража или подбор учетных данных для входа в систему под видом легального администратора.
T7	Процесс: LibraryApp	Repudiation	Отрицание входа. Администратор может отрицать факт входа в систему или выполнения деструктивных действий, если не ведется надлежащий аудит.
T8	Процесс: LibraryApp	Denial of Service	Отказ в обслуживании приложения. Высокая нагрузка или специально сформированные запросы могут привести к недоступности приложения LibraryApp.
T9	Поток: Параметры и фильтры	Tampering	Подмена команд между процессами. Злоумышленник может перехватить и изменить запрос, передаваемый от LibraryApp к LibraryDatabase.
T10	Процесс: LibraryApp	Elevation of Privilege	Удаленное выполнение кода (RCE). Уязвимость в приложении может позволить выполнить произвольный код на сервере, что эквивалентно получению полного контроля над ним.
T11	Процесс: LibraryDatabase	Tampering	SQL-инъекция. Внедрение злонамеренного SQL-кода через параметры приложения позволяет читать, изменять или удалять данные в БД без авторизации.

T12	Хранилище: PostgreSQL DB	Denial of Service	Отказ в обслуживании БД. Эксплуатация уязвимостей в СУБД может привести к ее аварийной остановке или истощению ресурсов, делая базу данных недоступной.
T13	Хранилище: PostgreSQL DB	Tampering	Подмена данных в БД. Эксплуатация уязвимостей может позволить напрямую изменять данные в базе, минуя бизнес-логику приложения.
T14	Хранилище: PostgreSQL DB	Information Disclosure	Утечка данных из БД. Уязвимости конфигурации или ПО СУБД могут привести к несанкционированному раскрытию всей хранимой информации.

Расчет риска

Расчет риска по методологии DREAD приведен в Таблице 2.

Таблица 2 – Расчет риска по DREAD

ID	Угроза	D	R	E	A	D	Риск
T1	Перехват учетных данных	3	3	2	3	3	14
T2	Подмена данных пользователя	2	2	2	2	2	10
T3	Перехват команд и данных	2	2	2	2	2	10
T4	Подмена команд и данных	3	2	2	3	2	12
T5	Перехват данных из БД	2	2	2	2	2	10
T6	Подбор учетных данных	3	3	2	3	3	14

T7	Отрицание входа	1	3	3	2	3	12
T8	Отказ в обслуживании приложения	2	2	2	2	2	10
T9	Подмена команд между процессами	3	2	2	3	2	12
T10	Удаленное выполнение кода (RCE)	3	2	2	3	2	12
T11	SQL-инъекция	3	3	3	3	3	15
T12	Отказ в обслуживании БД	2	2	2	3	2	11
T13	Подмена данных в БД	3	2	2	3	2	12
T14	Утечка данных из БД	3	2	2	3	2	12

Ранжирование угроз и меры митигации

Ранжированные угрозы и меры митигации приведены в Таблице 3.

Таблица 3 – Ранжированные угрозы и меры митигации

Уровень Риска	ID	Угроза	Оценка Риска	Рекомендуемые меры защиты
Критический	T11	SQL-инъекция	15	Строгое использование параметризованных запросов (Prepared Statements), ORM, валидация и санация всех входящих пользовательских данных.
Высокий	T1	Перехват учетных данных	14	Обязательное использование TLS 1.2+ для всего трафика, включая аутентификацию. Хэширование паролей с солью на стороне сервера.

Высокий	T6	Подбор учетных данных	14	Внедрение многофакторной аутентификации (MFA). Политика сложных паролей. Rate Limiting на попытки входа. Защита от User Enumeration.
Высокий	T4	Подмена команд и данных	12	Применение TLS для шифрования всего трафика между клиентом и сервером. Проверка целостности данных на стороне приложения.
Высокий	T7	Отрицание входа	12	Детальное логирование всех событий аутентификации и действий пользователей с привязкой к учетной записи и временной меткой.
Высокий	T9	Подмена команд между процессами	12	Шифрование и аутентификация трафика между внутренними компонентами системы (mTLS).
Высокий	T10	Удаленное выполнение кода (RCE)	12	Регулярное обновление и патчинг ПО, использование принципа минимальных привилегий, харденинг ОС и веб-сервера.
Высокий	T13	Подмена данных в БД	12	Своевременное обновление СУБД, минимализация привилегий учетной записи приложения в БД, регулярный аудит целостности данных.
Высокий	T14	Утечка данных из БД	12	Харденинг СУБД, шифрование конфиденциальных данных на уровне таблиц (TDE), строгое управление доступом на основе ролей (RBAC).
Средний	T12	Отказ в обслуживании БД	11	Настройка мониторинга ресурсов СУБД, ограничение числа соединений, использование WAF для фильтрации вредоносных запросов.
Средний	T2	Подмена данных пользователя	10	Принудительное использование TLS, проверка сертификатов на стороне клиента (если применимо).
Средний	T3	Перехват команд и данных	10	Шифрование всего трафика с использованием TLS.

Средний	T5	Перехват данных из БД	10	Шифрование трафика (TLS) между всеми компонентами системы.
Средний	T8	Отказ в обслуживании приложения	10	Внедрение Rate Limiting, использование WAF, мониторинг аномальной активности, резервирование.

Соответствие угроз БДУ ФСТЭК

Соответствие угроз БДУ ФСТЭК приведено в Таблице 4.

Таблица 4 – Соответствие угроз БДУ ФСТЭК.

ID	Наша угроза	Соответствующая угроза из БД ФСТЭК	Идентификатор ФСТЭК
T11	SQL-инъекция	УБИ.113 Нарушение безопасности (конфиденциальности, целостности) информации, обрабатываемой СУБД, в результате НСД к ней с применением вредоносных программ (программ-шифровальщиков, программ для DDoS-атак, программ для несанкционированного майнинга, другого вредоносного программного обеспечения)	УБИ.113 (Аналог по воздействию)
T1	Перехват учетных данных	УБИ.1 Перехват информации, циркулирующей в технических средствах и системах, по каналам связи	УБИ.1
T6	Подбор учетных данных	УБИ.19 Подделка идентификационной и аутентификационной информации (идентификаторов, аутентификаторов)	УБИ.19
T4	Подмена команд и данных	УБИ.9 Нарушение безопасности (целостности) информации, обрабатываемой техническими средствами системы	УБИ.9

T10	Удаленное выполнение кода (RCE)	УБИ.114 Нарушение безопасности (доступности, целостности) сервиса, обеспечивающего взаимодействие удаленных абонентов, в результате НСД к нему с применением вредоносных программ (программ-шифровальщиков, программ для DDoS-атак, программ для несанкционированного майнинга, другого вредоносного программно обеспечения)	УБИ.114 (Аналог по механизму)
-----	---------------------------------------	--	----------------------------------